

My Health @ EU
eHealth Digital Service Infrastructure
A service provided by the European Union

My Health @ EU
eHealth Digital Service Infrastructure
Electronic cross-border health services in the EU

eHealth DSI

Section I – Security Policies

DOCUMENT VERSION 10.0.0

DATE 01/06/2026

STATUS Wave 10 Operation Ready

DG SANTE, CEF eHealth DSI, 2026
Reuse is authorised, provided the source is acknowledged.

COVER AND CONTROL PAGE OF DOCUMENT	
Document old name:	D3.7.2 SECURITY SERVICES SPECIFICATION - Security Policy -
Document name:	Section I – Security Policies
Distribution level*:	PU
Status:	Wave 10 Operation Ready
Author(s): Organization:	eHealth DSI provider

* Distribution level: PU = Public, PP = Restricted to other programme participants, RE = Restricted to a group specified by the consortium, CO = Confidential, only for members of the consortium.

ABSTRACT
This document describes the security policy. Security is a critically important issue for eHealth DSI. Without adequate security in place none of the services can be used in real-life environments. A security policy is therefore needed to define a secure operational environment for the deployed services and create a 'chain of trust' among all eHealth DSI actors that will make possible the implementation of the cross border services. The security policy must be sufficient for protecting the data and processes, implementable and agreed upon by all partners. The security policy must be periodically re-examined. It must also be periodically audited to ensure member's conformance and compliance with its provisions.

CHANGE HISTORY				
Version	Date	Status Changes	From	Review
V10.0.0	01/06/2026	Wave 10 Release Candidate: CP090-EUDI Wallet integration updates	eHealth DSI Solution Provider	
V10.0.0-RC	04/05/2026	Wave 10 Release Candidate: CP090-EUDI Wallet integration updates	eHealth DSI Solution Provider	
V7.0.0	18/07/2023	Wave 7 Operation ready Administrative	eHealth DSI Solution Provider	

		update		
V7.0.0	05/06/2023	Administrative update (Version-bump). No content updates.	eHealth DSI Solution Provider	
V6.1.0	29/07/2022	Wave 6 Operation Ready	eHealth DSI Solution Provider	• Review of the deprecated links
V6.0.0	21/04/2022	Wave 6 Release Candidate	eHealth DSI Solution Provider	
V5.0.0	23/04/2021	Wave 5 Release Candidate	eHealth DSI Solution Provider	
V4.1.0	08/06/2020	Wave 4 Operation Ready	eHealth DSI Solution Provider	• Clarification of the end-to-end Security definition • Addition of a link to the Requirement Catalogue • Deletion of the term *Security Audit Policy*
V4.0.0	29/04/2020	Wave 4 Release Candidate	eHealth DSI Solution Provider	• Explanation of End-to-end Security requirement • Removal of duplicate between the Requirement Catalogue and the document (Security Rules)
V3.0.0	20/07/2019	Administrative update (Version-bump). No content updates.	eHealth DSI Solution Provider	
V2.2.0	30/06/2018	Wave 2 Operation Ready	eHealth DSI Solution Provider	
V2.1.0	01/06/2017	Wave 1 Operation Ready – Released for eHMSEG adoption	eHealth DSI Solution Provider	

V2.0.0	28/03/2017	Remove all references to epSOS and requirements	eHealth DSI provider	

TABLE OF CONTENTS

1 The Security Policy 6
1.1 Need and Scope *6*
1.2 Principles and Objectives *6*
1.2.1 Principles 6
1.2.2 Objectives 7
1.3 Security Rules *7*
1.4 Audit *9*
1.5 References *9*

1 The Security Policy

1.1 Need and Scope

Security is a critically important issue for eHealth DSI. Without adequate security in place none of the services can be used in real-life environments. The security policy aims to create a secure operational environment for the service deployment which will be sufficient for protecting the data and processes, implementable and agreed by all participants. The security policy specifies the rules under which a secure operational environment for eHealth DSI, helps develop a 'chain of trust' among eHealth DSI partners. The security policy also specifies the obligations of service providers and users and must be approved, implemented and periodically audited by all eHealth DSI partners, as described in the next sections.

eHDSI requires an end-to-end security, from the Health Professional in the country of Treatment, to the medical information located in the Country of Affiliation, **ensuring the confidentiality, integrity and availability** of the exchanged information.

As an important note, in all eHDSI documentation (specifications, frameworks), the use of the term end-to-end encryption, implicitly refers to the end-to-end security, and does not imply an uninterrupted chain of encryption. Each Member State has the responsibility to implement the appropriate and feasible technical solution to fulfil the eHDSI Security Policies and objectives.

End-to-end security in eHDSI ensures the access by National Contact Points of the exchanged data, for auditability, transcoding and translating purposes.

It must also ensure the possibility to repair or debug the different modules of the application, when required.

1.2 Principles and Objectives

1.2.1 Principles

All data and processes must be adequately protected. The network build among the eHealth DSI partners should also not add any unacceptable new risk within any partner organisation. Appropriate technologies and procedures must be used to ensure that data is stored processed and transmitted securely over the network build among the eHealth DSI partners and is only disclosed to authorized parties.

Information security is generally characterized as the protection of (a) *Confidentiality* (information is protected from unauthorized access or unintended disclosure - only authorized users have access to the information and other system resources), (b) *Integrity* (information is protected from unauthorized modification), (c) *Availability* (resources are available, without unreasonable delay - authorized users are able to access information and the related means when they need it).

The security policy should help to ensure and enforce the above. It should also provide means of proof and essential checks, which give users, trust in the given information.

1.2.2 Objectives

The objective of the security policy is to establish the basic security provisions that must be satisfied to ensure the security of data and system continuity and to prevent and minimise the impact of security incidents by implementing a stable, reliable and secure infrastructure.

More specifically, the security policy objectives are:

1. To make actors sensitive in the operated means of protection and in the risks which they cover.

2. To create a general security framework adapted to the eHealth DSI information system needs, to be followed by those in charge of processes, and to put in place measures and procedures to ensure the information and eHealth DSI information system and infrastructure security.

3. To promote cooperation between various actors of the consortium in order to elaborate and put in place those measures, instructions and procedures.

4. To enhance health professional and patients trust in the information system.

5. To ensure that the information system in place respects the National and European legislation on privacy and data protection in force.

The security policy is constructed under the principle of well-proportioned answer to the incurred risk.

1.3 Security Rules

Security Rules have been integrated as requirements of the Requirements Catalogue, available at the link: *https://webgate.ec.europa.eu/fpfis/wikis/x/e_HzN*

The following general security rules are required and apply for the data exchange model:

Security Rule	Description	Corresponding eHDSI Requirement
SR 1	Data flows must be adequately protected, as specified in international standards.	09.01. Ensure confidentiality of the services, data and systems
SR 2	End users must be clearly identified by national infrastructure before being able to enter the system.	01.01. Uniquely identify and authenticate the Health Professional (HP) in Country of treatment
SR 3	Mutual authentication between End Users and the national infrastructure's identity providers is needed when connecting to the system.	09.01. Ensure confidentiality of the services, data and systems
SR 4	End user identification and authentication procedures in place must have been audited *according to the audit policy.*	09.01. Ensure confidentiality of the services, data and systems
SR 5	The audit policy must be implemented. The types of audit procedures to be applied are defined by eHOMB. Audit logs must not contain clinical payload and must pseudonymise patient identifiers.	09.06. Ensure auditability of the exchanged data

SR 6	Mutual Authentication between national contact point providers (NCPs) of different countries is needed, when initiating a trans-European (cross border) information flow.	09.01. Ensure confidentiality of the services, data and systems
SR 7	Non-repudiation procedures must be implemented between the User-Originator and the User-Receiver of documents and messages.	10.01. Handle the non-repudiation mechanism
SR 8	All eHealth DSI actors in a Country B must ensure that any medical document is forwarded only to the user that has been authorized to access the document.	9.01. Ensure confidentiality of the services, data and systems
SR 9	The software used to implement the NCP gateway must conform to the technical specifications of eHealth DSI architecture and common components.	9.01. Ensure confidentiality of the services, data and systems
SR 10	Any NCP-B deployment using the EUDI Wallet as a patient identification channel MUST be registered as an EUDI Wallet Relying Party with the competent authority of the member state in which it operates, in accordance with Article 5b of Regulation (EU) 2024/1183 (eIDAS 2.0). The RP registration certificate MUST be used to sign all OpenID4VP authorization_request JWTs issued by the NCP-B EUDI connector.	09.01. Ensure confidentiality of the services, data and systems
SR 11	When a patient presents their EUDI Wallet PID credential to an NCP-B, the NCP-B MUST validate the VP Token in full before accepting any identity claim. Validation MUST include: (a) nonce verification; (b) PID issuer trust chain verification against the EU Trusted List for EUDI Wallet issuers; (c) credential signature verification; (d) selective disclosure proof verification; (e) credential validity period check; (f) revocation check where technically feasible. Any VP Token failing one or more of these checks MUST be rejected and MUST NOT be used as the basis for a TRC Assertion.	09.01. Ensure confidentiality of the services, data and systems
SR 12	The NCP-B MUST apply the principle of data minimisation when requesting PID claims from a patient's EUDI Wallet. Only the claims strictly necessary for patient identification in the XCPD transaction (given name, family name, date of birth, and where available national administrative number) MUST be requested. The intent_to_retain flag MUST be set to false for all requested claims.	09.01. Ensure confidentiality of the services, data and systems

SR 13	The NCP-B MUST write an audit trail entry for every EUDI Wallet patient identification event, recording the event outcome, the issuing member state of the PID credential, and whether VP Token validation succeeded or failed. The audit entry MUST NOT contain the raw VP Token, the full PID claim set, or any patient health data. Audit logs for EUDI wallet events are subject to the same pseudonymisation and retention obligations as all other eHDSI audit entries.	09.06. Ensure auditability of the exchanged data

Rules SR 2, SR 3 and SR 4 are national (national level) competency, while rules SR 5, SR 6, SR 7, and SR 8 are a pan European (eHealth DSI level) competency.
Rules SR 10–SR 13 apply exclusively to NCP-B deployments that activate the EUDI Wallet identification channel. Member states that do not deploy this feature are not subject to these rules. NCP-A deployments are not affected by any of these rules.

In addition, eHealth DSI actors and processes must also take into account the relevant security provisions of:

- Multilateral Agreement [MLA]
- The security recommendations of the Guidelines of an Organisational Framework for eHealth NCP [Security Recommendations OFW]
- The European Interoperability Framework [EIF] for European Public Services

1.4 Audit

Each National NCP must undergo an initial audit as defined in [eHealth DSI Audit Framework].

1.5 References

Guideline on an Organisational Framework for eHealth NCP
http://ec.europa.eu/health//sites/health/files/ehealth/docs/ev_20151123_co01_en.pdf

[MLA] Multilateral Legal Agreement